

TS ACADEMY

CYBER SECURITY CAPSTONE PROJECT

Project Title

From Vulnerability to Compliance: Securing Legacy Systems at Apex Healthcare Solutions

Submitted by:

OREFUWA DAVID MAYOWA

Group Number: 22

JULY, 2026

1. EXECUTIVE SUMMARY

This Security Assessment Report presents the findings of a cybersecurity assessment conducted on two legacy systems, Kioptrix and Metasploitable 2, operating within the Apex Healthcare Solutions environment. The purpose of the assessment was to identify existing security vulnerabilities, evaluate the business risks associated with those vulnerabilities, and recommend appropriate technical controls and governance policies to improve the organization's cybersecurity posture.

To strengthen the organization's security posture, this report recommends implementing a structured patch management program, replacing insecure services such as FTP and Telnet with secure alternatives, enforcing Multi-Factor Authentication (MFA), strengthening password policies, hardening databases and servers, conducting regular vulnerability assessments, and implementing Governance, Risk, and Compliance (GRC) policies.

Key Findings

The assessment identified six significant vulnerabilities across the two legacy systems. The most critical issues include outdated software components such as Apache, Samba, FTP, and MySQL, weak authentication mechanisms, and the continued use of insecure legacy services such as Telnet. These vulnerabilities expose the organization to unauthorized access, data breaches, service disruptions, regulatory non-compliance, and potential reputational damage.

Highest-Risk Vulnerabilities

- Outdated Samba Service (Kioptrix)
- Outdated Apache Web Server (Kioptrix)
- Insecure FTP Service (Metasploitable 2)
- Telnet Service Enabled (Metasploitable 2)

These vulnerabilities are associated with publicly documented security weaknesses that can be exploited using widely available attack techniques. Successful exploitation could result in unauthorized access to sensitive patient information, compromise of critical systems, disruption of healthcare services, and significant financial and reputational consequences.

Recommended Security Controls

To strengthen the organization's security posture, this report recommends;

- Implement a comprehensive Patch Management process.
- Enforce Multi-Factor Authentication (MFA) and strong password policies.
- Replace insecure protocols such as Telnet and FTP with SSH and SFTP.
- Harden server and database configurations.

- Conduct regular vulnerability assessments, continuous security monitoring, and periodic security audits.
- Implementing Governance, Risk, and Compliance (GRC) policies.

Recommended GRC Policies

- Access Control Policy
- Password Policy
- Patch Management Policy
- Vulnerability Management Policy

Implementing these policies will establish standardized security practices, strengthen organizational governance, reduce cybersecurity risks, and support compliance with healthcare information security regulations and industry best practices.

Overall Security Posture

The overall security posture of the assessed legacy systems is classified as High Risk. The presence of multiple outdated services, insecure communication protocols, and weak authentication mechanisms significantly increases the organization's exposure to cyber threats. However, implementing the recommended technical controls and GRC policies will significantly reduce the organization's attack surface, enhance resilience against evolving cyber threats, and strengthen the confidentiality, integrity, and availability of critical healthcare information. Management should prioritize remediation of high-risk vulnerabilities, establish a formal vulnerability management program, and maintain continuous security monitoring to ensure ongoing compliance and continuous security improvement.

This security assessment was conducted to evaluate the security posture of two legacy systems, Kioptrix and Metasploitable 2, operating within the Apex Healthcare Solutions environment. The primary objective was to identify existing security vulnerabilities, assess their associated business risks, and recommend appropriate technical security controls and Governance, Risk, and Compliance (GRC) policies to strengthen the organization's cybersecurity posture and support regulatory compliance.

2. VULNERABILITY ASSESSMENT FINDINGS

A. Kioptrix

Vulnerability 1: Outdated Operating System

Description

The server runs an outdated Linux operating system that no longer receives security updates.

Why It Is Dangerous?

Attackers can exploit publicly known vulnerabilities because no security patches are available.

Business Risk

- Unauthorized system access
- Service interruption
- Increased likelihood of malware infection

Recommended Controls

- Upgrade to a supported operating system.
- Implement regular patch management.
- Remove unsupported software from production.

Vulnerability 2: Weak SMB Configuration

Description

The SMB service exposes outdated protocols and insecure configurations.

Why It Is Dangerous?

Poor SMB configurations can allow attackers to gain unauthorized access or move laterally within the network.

Business Risk

- Unauthorized file access
- Internal network compromise
- Data leakage

Recommended Controls

- Disable SMBv1.
- Restrict SMB access using firewalls.
- Enable SMB signing.
- Monitor SMB activity.

Vulnerability 3: Outdated Apache Web Server

Description

An old version of Apache is running with publicly documented vulnerabilities.

Why It Is Dangerous?

Web server vulnerabilities may allow attackers to execute malicious code or gain unauthorized access.

Business Risk

- Website compromise
- Exposure of patient information
- Service downtime

Recommended Controls

- Upgrade Apache.
- Remove unnecessary modules.
- Enable a Web Application Firewall (WAF).
- Conduct regular vulnerability scanning.

Vulnerability 4: Weak User Authentication

Description

The system allows weak passwords and does not have security features to protect user accounts from unauthorized access.

Why It Is Dangerous

Weak credentials increase the likelihood of brute-force attacks.

Business Risk

- Unauthorized users may gain access to the system.
- Attackers may increase privileges and take control of critical systems.
- Sensitive company and customer data may be stolen, resulting in financial loss, regulatory penalties, and reputational damage.

Recommended Controls

- Enforce strong password policies.
- Implement Multi-Factor Authentication (MFA).
- Enable account lockout after failed login attempts.

B. Metasploitable 2

Vulnerability 1: Vulnerable FTP Service (vsftpd)

Description

The FTP server is outdated and insecure.

Why It Is Dangerous?

Attackers may gain unauthorized access through weaknesses in the FTP service.

Business Risk

- Unauthorized users may gain access to sensitive files.
- Attackers may upload malicious files that could compromise the system.
- Sensitive business and customer data may be exposed, leading to financial loss, regulatory penalties, and reputational damage.

Recommended Controls

- Disable the FTP service if no longer required.
- Replace FTP with SFTP or FTPS.
- Restrict file transfer permissions using the Principle of Least Privilege (PoLP).

Vulnerability 2: Insecure Telnet Service**Description**

The system uses Telnet, which sends usernames and passwords in plain text without encryption.

Why It Is Dangerous?

Attackers can intercept login credentials during transmission and use them to gain unauthorized access.

Business Risk

- Theft of user credentials.
- Unauthorized system access.
- Regulatory non-compliance, fines, and reputational damage.

Recommended Controls

- Disable Telnet.
- Replace Telnet with SSH.
- Restrict remote administrative access to authorized users only.

Vulnerability 3: Outdated Samba Service**Description**

The Samba service is outdated and contains known security vulnerabilities.

Why It Is Dangerous?

Attackers can exploit these vulnerabilities to access shared files, steal sensitive information, or gain unauthorized access.

Business Risk

- Unauthorized access to shared files.
- Exposure of sensitive business data.
- Compromise of other systems on the network.

Recommended Controls

- Update Samba to the latest secure version.
- Limit access to authorized users and trusted networks only.
- Apply the Principle of Least Privilege.

Vulnerability 4: Weak Database Security

Description

The MySQL database uses weak authentication and insecure default settings.

Why It Is Dangerous?

Attackers may gain unauthorized access to the database and view, modify, or steal sensitive information.

Business Risk

- Theft of sensitive patient and business data.
- Loss of data integrity through unauthorized changes.
- Regulatory penalties and reputational damage.

Recommended Controls

- Use strong passwords and MFA where possible.
- Remove default accounts and change default settings.
- Encrypt sensitive data stored in the database.
- Limit database access to authorized users and systems only.

Vulnerability Identification

System	Vulnerability	Affected Service	Description	Business Risk
Kioptrix	Outdated Samba Service	Samba (SMB)	Runs an outdated version containing publicly known vulnerabilities.	Unauthorized access, privilege escalation, and data breaches.
Kioptrix	Outdated Apache Web Server	Apache HTTP Server	Missing critical security updates.	Website compromise, service disruption, and sensitive data exposure.
Kioptrix	Weak SSH Authentication	SSH	Weak passwords increase the likelihood of brute-force attacks.	Unauthorized administrative access and complete system compromise.
Metasploitable 2	Insecure FTP Service	FTP (vsftpd)	File transfers occur without encryption.	Credential theft, malware uploads, and unauthorized file access.
Metasploitable 2	Telnet Enabled	Telnet	Credentials are transmitted in plain text.	Credential interception and unauthorized remote access.
Metasploitable 2	Outdated MySQL Configuration	MySQL	Default configurations and outdated software expose databases.	Theft, modification, or destruction of sensitive patient information.

3. RISK ASSESSMENT

Vulnerability	Likelihood	Impact	Risk Rating	Business Impact
Outdated Samba Service	High	High	High	Attackers may gain unauthorized access and compromise sensitive healthcare data.
Outdated Apache Web Server	High	High	High	May lead to web server compromise and disruption of healthcare services.
Weak SSH Authentication	Medium	High	High	Administrative accounts may be compromised through brute-force attacks.
Insecure FTP Service	High	High	High	Sensitive files and credentials may be intercepted or modified.
Telnet Enabled	High	High	High	Plain-text credentials may be captured by attackers.
Outdated MySQL Configuration	Medium	High	High	Patient records may be accessed, modified, or deleted without authorization.

Overall Risk Assessment

The assessment concludes that Apex Healthcare Solutions has an overall High Risk security posture. The combination of outdated software, insecure communication protocols, weak authentication mechanisms, and poor database security significantly increases the likelihood of cyberattacks. Successful exploitation could result in data breaches, disruption of healthcare services, financial losses, legal penalties, and reputational damage.

4. RECOMMENDED SECURITY CONTROLS

Vulnerability	Recommended Control	Expected Outcome
Outdated Samba Service	Implement Patch Management	Eliminates known vulnerabilities and reduces attack opportunities.
Outdated Apache Web Server	Regular Software Updates and Web Application Firewall (WAF)	Protects web applications and addresses known vulnerabilities.
Weak SSH Authentication	Multi-Factor Authentication (MFA) and Strong Password Policy	Reduces unauthorized administrative access.
Insecure FTP Service	Replace FTP with SFTP or FTPS	Encrypts file transfers and protects credentials.
Telnet Enabled	Disable Telnet and Replace with SSH	Encrypts administrative communication.
Outdated MySQL Configuration	Database Hardening and Access Control	Secures sensitive healthcare databases against unauthorized access.

Additional Technical Recommendations:

- Establish a formal vulnerability management program.
- Conduct regular vulnerability assessments and penetration testing.
- Deploy continuous security monitoring using a SIEM solution.
- Enforce the Principle of Least Privilege (PoLP).
- Encrypt sensitive patient information both in transit and at rest.
- Maintain regular system backups and disaster recovery procedures.
- Deliver cybersecurity awareness training to all employees.

5. RECOMMENDED GRC POLICIES

Access Control Policy

Ensure access to systems and patient information is granted only to authorized personnel according to the Principle of Least Privilege. Benefits: Prevents unauthorized access, protects sensitive healthcare information, supports regulatory compliance.

Password Policy

Define password complexity requirements, password expiration, account lockout thresholds, and mandatory MFA. Benefits: Strengthens authentication, reduces brute-force attacks, improves account security.

Patch Management Policy

Ensure timely installation of security updates. Benefits: Eliminates known vulnerabilities, reduces cyberattack opportunities, improves system security.

Vulnerability Management Policy

Establish procedures for identifying, assessing, prioritizing, remediating, and monitoring vulnerabilities. Benefits: Supports proactive cybersecurity, reduces organizational risk, improves regulatory compliance.

Acceptable Use Policy

Define appropriate use of organizational computers, networks, internet services, and healthcare information systems. Benefits: Reduces insider threats, encourages responsible technology use, protects organizational resources.

6. CONCLUSION

The cybersecurity assessment conducted on the Kioptrix and Metasploitable 2 legacy systems identified several critical vulnerabilities that expose Apex Healthcare Solutions to significant cybersecurity risks. Outdated software, insecure communication protocols, weak authentication mechanisms, and insecure database configurations create opportunities for attackers to compromise sensitive healthcare information and disrupt essential business operations.

The overall risk level was assessed as High, requiring immediate remediation. Priority should be given to patching outdated systems, replacing insecure services such as FTP and Telnet with secure alternatives, implementing MFA, strengthening password security, and hardening server and database configurations.

In addition to technical improvements, Apex Healthcare Solutions should implement comprehensive GRC policies including Access Control, Password Management, Patch Management, Vulnerability Management, and Acceptable Use policies. These measures will improve regulatory compliance, strengthen organizational resilience, and establish a proactive cybersecurity culture.

By implementing the recommendations outlined in this report, Apex Healthcare Solutions will significantly improve the confidentiality, integrity, and availability of its healthcare systems while reducing the likelihood and impact of future cyber threats.